

DPIA Guide in Plain Language

How to fill in the DPIA template — for GDPR and India's DPDP Act

1. What is a DPIA?

A **Data Protection Impact Assessment (DPIA)** is a written check you do **before** you start using people's personal data in a new or risky way. It asks four simple questions: **What are we doing? Do we really need to? What could go wrong for the people involved? How will we stop it?** A senior person then signs to say they have seen the risks and accept what is left.

2. Do we need one?

- **GDPR (Europe/UK):** yes, when the use of data is *likely to be high risk* — for example profiling people, using a lot of health or biometric data, watching people at large scale, or using new technology such as AI.
- **DPDP Act (India):** mandatory **once every 12 months** for **Significant Data Fiduciaries** — big or high-risk organisations that the Government notifies (Rule 13). This is scheduled to start on **13 May 2027**; a shorter deadline was discussed but not confirmed, so check for updates. Other organisations do not have to, but it is good practice — especially for children's data.
- **Rule of thumb:** if two or more warning signs apply (profiling, sensitive data, large scale, children, monitoring, new technology), do a full DPIA. If unsure, do a quick one.
- **Timing:** do it **before** the project goes live, not after.

3. Words you will see

Term	What it means
Controller / Data Fiduciary	The organisation that decides why and how personal data is used.
Data subject / Data Principal	The person the data is about.
Regulator / the Board	The authority that enforces the law (in India: the Data Protection Board).
DPO / Privacy Lead	The privacy expert who advises you. They advise; senior management decides.
Processor / vendor	A company that handles data on your behalf (e.g., a cloud or payment provider).
RoPA	Record of Processing Activities — your master list of how data is used.

4. The template at a glance

Template part	The question it answers	Who helps
Document control	Who owns this DPIA, and when is it reviewed?	Assessment owner
Threshold assessment	Do we need a DPIA at all?	DPO / Legal
Description of processing	What exactly are we doing with the data?	Business owner, IT
Necessity assessment	Are we allowed to — and do we really need it?	Legal, DPO
Risk identification	What could go wrong for people?	Everyone involved
Mitigation measures	How do we reduce each risk, and are we ready for a breach?	Security, IT, control owners
Sign-off	Who has reviewed it and accepts the leftover risk?	DPO, senior management

5. Filling in the template, step by step

Step 1 — Document control. Fill this in first. Give the DPIA a reference number, name one owner, list the DPO you asked, and set a **review date** (for Significant Data Fiduciaries, within 12 months). Note the laws that apply (GDPR, UK GDPR, DPDP).

Step 2 — Threshold assessment. Tick which high-risk signs apply and write one or two lines explaining your decision. If you decide *no DPIA*, keep that note — it proves you thought about it.

Step 3 — Describe the processing. Write so that someone outside your team can follow it.

- **Overview:** a summary in 150 words or less — what, why, for whom, how many people, how long, and whether it is new or a change. Say if it is “large scale” and why.
- **Categories and sources:** list the types of data (identity, contact, location, financial, online activity, sensitive, children’s) and where each comes from (the person, their device, public sources, an employer, a third party, the Government).
- **Inventory:** go field by field (e.g., email, phone, location). For each, ask “*do we truly need this?*” and mark it. **If not needed, stop collecting it.** Mark anything sensitive.
- **Lifecycle:** follow the data from collection to deletion — where it is stored, who can see it, who it is shared with, and how long it is kept. A simple flow helps: *Person → Collection → App → Internal processing → Vendor → Storage → Use → Retention → Deletion*.

Step 4 — Necessity assessment. Prove you are allowed to use the data, and that you are not using more than you need.

Lawful basis. Under the DPDP Act, every purpose needs either **consent** (section 6) or a **legitimate use** (section 7) such as a legal duty, a medical emergency, employment, a State function, or data the person volunteered. Under GDPR, choose one of the six legal bases for each purpose.

If you rely on consent, check that it is:

- free, specific, informed, unconditional and clear (the person actively agrees) — and only for data needed for that purpose;
- preceded by a plain-language notice that lists the data, the purpose, how to withdraw consent and how to complain (section 5; Rule 3);
- as easy to withdraw as it was to give; with a Consent Manager option where it applies (Rule 4);
- backed by **verifiable parent or guardian consent** for children (under 18) or persons with a lawful guardian (section 9; Rules 10–11).

Principles test — answer Yes/No with evidence for each. Every “No” becomes a risk in Step 5.

Principle	Ask yourself
Purpose limitation	Is each purpose clear and legitimate? Is any later use still compatible?
Necessity	Could we reach the goal with less data or none? What alternatives did we reject, and why?
Data minimisation	Is every item in the inventory adequate, relevant and limited to what we need?
Accuracy	How do we keep data correct and complete, especially when it drives decisions?
Storage limitation	Are retention periods set, justified and enforced? Is deletion automatic? (DPDP Rule 8 includes a 48-hour advance erasure notice.)
Integrity and confidentiality	Are reasonable security safeguards in place?
Transparency	Do notices explain purposes, recipients, transfers, retention, rights and contacts — in words everyone (including children) can understand?
Accountability	Is this activity in our RoPA?
Proportionality	Is the privacy intrusion fair compared with the benefit?

Step 5 — Identify and score risks. For each thing that could go wrong *for a person*, write one clear line (cause → event → harm) in the risk register. Then score it:

Risk score = Likelihood (1–5) × Severity (1–5)

Score	Likelihood	Severity (effect on the person)
1	Rare	Negligible, minor inconvenience
2	Unlikely	Limited, recoverable
3	Possible	Significant, recoverable with difficulty
4	Likely	Serious, hard to reverse
5	Almost certain	Severe, irreversible damage

Rating	Score	Example
Low	1–4	
Medium	5–9	
High	10–16	Likely (4) × Serious (3) = 12 → High
Very High	17–25	

Risk prompts: unauthorised access or breach · data loss · discrimination or unfair treatment · loss of confidentiality · excessive monitoring · loss of control · not being able to use rights · wrong or harmful decisions · financial harm · physical or safety harm · harm to children or vulnerable people · keeping data too long · using data for new purposes (function creep) · unclear notices · cross-border transfers · re-identification.

Step 6 — Reduce the risks. For every risk, fill in: control, type (technical / organisational / legal), owner, date, evidence, how you will monitor it, and whether the leftover risk is accepted. Then **score again**.

- **Best fix first:** remove the problem (collect less, delete sooner, anonymise) before adding locks (encryption, access controls, logging) or paperwork (policies, training, contracts).
- **Only count a control once it has an owner and a date.** An idea does not lower the score.

Be ready for a breach

	GDPR	DPDP Act / Rules 2025
Tell the regulator	Within 72 hours of becoming aware, if there is a risk to people (Art. 33)	Detailed report to the Board within 72 hours (Rule 7)
Tell the people affected	Without undue delay, if the risk is high (Art. 34)	Without delay, in every breach (Rule 7)
Keep a record	Art. 33(5)	Section 8(6)

Also check: privacy notice is clear and tested · rights requests (access, correction, erasure) have a working process · grievance contact is published · a human can review automated decisions. Then **update your records:** RoPA, privacy notice, consent records, vendor contracts, cross-border register, retention schedule and incident plan.

Step 7 — Sign-off. The **DPO advises:** proceed, proceed with conditions, consult the regulator first, or report to the Board. **Senior management decides** and signs the approval statement: *the DPIA describes the processing accurately, the risks and measures were reviewed, and remaining risks and conditions are documented.* If management goes against the DPO's advice, write down why.

This guide is a working aid, not legal advice. Laws and dates (especially DPDP commencement) can change — confirm with your DPO or counsel.